

NORMA
BRASILEIRA

ABNT NBR
ISO/IEC
38506

Primeira edição
28.10.2025

**Tecnologia da informação — Governança de TI
— Aplicação da ABNT NBR ISO/IEC 38500
à governança de investimentos habilitados por TI**

*Information technology — Governance of IT — Application
of ABNT NBR ISO/IEC 38500 to the governance of IT enabled investments*

ICS 35.020



ASSOCIAÇÃO
BRASILEIRA
DE NORMAS
TÉCNICAS

Número de referência
ABNT NBR ISO/IEC 38506:2025
16 páginas

© ISO/IEC 2020 - © ABNT 2025



© ISO/IEC 2020

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT, único representante da ISO no território brasileiro.

© ABNT 2025

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT.

ABNT

Rua Conselheiro Nebias, 1.131

01203-002 - São Paulo - SP

Tel.: + 55 11 3017-3600

abnt@abnt.org.br

www.abnt.org.br

Sumário

Página

Prefácio Nacional	v
Introdução	vi
1 Escopo	1
2 Referência normativa	1
3 Termos e definições	2
4 Boa governança de investimentos habilitados por TI	2
4.1 Benefícios da boa governança dos investimentos habilitados por TI	2
4.2 Foco no valor	3
4.3 Responsabilização do órgão de governança	3
5 Modelo de boa governança de investimentos habilitados por TI	4
5.1 Modelo de boa governança aplicado à governança de investimentos habilitados por TI	4
5.1.1 Avaliar	5
5.1.2 Direcionar	6
5.1.3 Monitorar	6
6 Princípios para governança de investimentos habilitados por TI	7
6.1 Geral	7
6.2 Princípio 1 – Responsabilidade	7
6.2.1 Aplicação do princípio	7
6.2.2 Implicações para o órgão de governança	8
6.2.3 Resultados desejados	8
6.2.4 Comportamentos de governança	8
6.3 Princípio 2 – Estratégia	9
6.3.1 Aplicação do princípio	9
6.3.2 Implicações para o órgão de governança	9
6.3.3 Resultados desejados	10
6.3.4 Comportamentos de governança	10
6.4 Princípio 3 – Aquisição	10
6.4.1 Aplicação do princípio	10
6.4.2 Implicações para o órgão de governança	10
6.4.3 Resultados desejados	11
6.4.4 Comportamentos de governança	11
6.5 Princípio 4 – Desempenho	11
6.5.1 Aplicação do princípio	11
6.5.2 Implicações para o órgão de governança	11
6.5.3 Resultados desejados	12
6.5.4 Comportamentos de governança	12
6.6 Princípio 5 – Conformidade	12
6.6.1 Aplicação do princípio	12
6.6.2 Implicações para o órgão de governança	13
6.6.3 Resultados desejados	13

6.6.4 Comportamentos de governança13

6.7 Princípio 6 – Comportamento humano13

6.7.1 Aplicação do princípio.....13

6.7.2 Implicações para o órgão de governança.....14

6.7.3 Resultados desejados14

6.7.4 Comportamentos de governança15

Bibliografia.....16

Figuras

Figura 1 – Modelo de governança de TI5



Prefácio Nacional

A Associação Brasileira de Normas Técnicas (ABNT) é o Foro Nacional de Normalização. As Normas Brasileiras, cujo conteúdo é de responsabilidade dos Comitês Brasileiros (ABNT/CB), dos Organismos de Normalização Setorial (ABNT/ONS) e das Comissões de Estudo Especiais (ABNT/CEE), são elaboradas por Comissões de Estudo (CE), formadas pelas partes interessadas no tema objeto da normalização.

Os Documentos Técnicos internacionais adotados são elaborados conforme as regras da ABNT Diretiva 3.

A ABNT chama a atenção para que, apesar de ter sido solicitada manifestação sobre eventuais direitos de patentes durante a Consulta Nacional, estes podem ocorrer e devem ser comunicados à ABNT a qualquer momento (Lei nº 9.279, de 14 de maio de 1996).

Os Documentos Técnicos ABNT, assim como as Normas Internacionais (ISO e IEC), são voluntários e não incluem requisitos contratuais, legais ou estatutários. Os Documentos Técnicos ABNT não substituem Leis, Decretos ou Regulamentos, aos quais os usuários devem atender, tendo precedência sobre qualquer Documento Técnico ABNT.

Ressalta-se que os Documentos Técnicos ABNT podem ser objeto de citação em Regulamentos Técnicos. Nestes casos, os órgãos responsáveis pelos Regulamentos Técnicos podem determinar as datas para exigência dos requisitos de quaisquer Documentos Técnicos ABNT.

A ABNT NBR ISO/IEC 38506 foi elaborada no Comitê Brasileiro de Tecnologias da Informação e Transformação Digital (ABNT/CB-021), pela Comissão de Estudo de Gestão e Governança de TI (CE-021:004.040). O Projeto foi submetido à Consulta Nacional no período de 18.09.2025 a 20.10.2025.

A ABNT NBR ISO/IEC 38506 é uma adoção idêntica, em conteúdo técnico, estrutura e redação, à ISO/IEC 38506:2020, que foi elaborada pelo *Technical Committee Information Technology* (ISO/IEC JTC 1), *Subcommittee IT service management and IT governance* (SC 40).

O Escopo em inglês da ABNT NBR ISO/IEC 38506 é o seguinte:

Scope

This document provides guidance on governance of IT enabled investments to the governing body of all forms of organizations, whether private, public or government entities, and will equally apply regardless of the size of the organization or its industry or sector. The terms business and business outcome throughout this document include all forms of organization covered by this document.

Introdução

Na era digital em rápida evolução hoje, o mundo está passando por mudanças imprevisíveis por meio de mudanças no poder político e econômico, combinadas com modelos de negócios disruptivos, avanços tecnológicos aparentemente constantes e abordagens inovadoras para conduzir negócios.

Como os órgãos de governança podem preparar suas organizações para enfrentar desafios novos e constantes, ao mesmo tempo em que estão prontos para um futuro cada vez mais orientado por informação e tecnologia?

A Tecnologia da Informação (TI) suporta as principais funções de todas as organizações, sustenta a base de quase todas as atividades de negócios e faz interface com clientes e outras partes interessadas. Os investimentos em capacitação de TI e a contribuição da TI para a capacidade de negócios e para o desempenho da organização exercem um papel significativo na realização de planos estratégicos e na entrega de valor comercial.

A governança eficaz dos investimentos habilitados por TI fornecerá aos órgãos de governança uma melhor compreensão de suas obrigações e como o valor é obtido para apoiar as oportunidades de negócios da organização e mitigar adequadamente os riscos organizacionais.

Os riscos incluem, por exemplo, falha em fornecer os recursos necessários, falha no alcance dos benefícios esperados pelo negócio, impacto resultando em, por exemplo, interrupções no negócio, descumprimento de obrigações legais, não conformidade regulatória, falhas de segurança, perda de dados e tempo de inatividade. A governança eficaz atua de forma proativa na prevenção ou mitigação dos aspectos de TI desses riscos, por exemplo, ao lidar com períodos prolongados de subinvestimento.

A governança de TI, incluindo investimentos em TI, faz parte de uma governança corporativa sólida. A governança de TI não é gestão de TI, mas convém que seja apoiada por uma estrutura de governança e pelo sistema de gestão de TI da organização.

Este documento fornece diretrizes aos membros dos órgãos de governança para aplicar os princípios e o modelo documentados na ABNT NBR ISO/IEC 38500 aos investimentos habilitados por TI. Ao longo deste documento, a palavra “investimentos” é sinônimo de investimentos habilitados por TI.

Tecnologia da informação — Governança de TI — Aplicação da ABNT NBR ISO/IEC 38500 à governança de investimentos habilitados por TI

1 Escopo

Este documento fornece orientações sobre a governança de investimentos habilitados por TI para o órgão de governança de todas as formas de organizações, sejam elas privadas, públicas ou entidades governamentais, e se aplica igualmente, independentemente do tamanho da organização ou de seu setor ou indústria. Os termos negócio e resultado de negócio, ao longo deste documento, abrangem todas as formas de organização abrangidas por este documento. Este documento também fornece orientação para outras partes que interagem com órgãos de governança, como pessoal do projeto, contadores, consultores de gestão, gerentes de portfólio de investimentos e equipe de suporte à governança.

Os investimentos habilitados por TI no escopo deste documento podem ser investimentos de qualquer escala, desde a aquisição de negócios até qualquer mudança de negócios incorporando TI, criando novos serviços corporativos ou abordando ganhos de eficácia e eficiência em serviços operacionais de TI para obter vantagem competitiva, sejam esses serviços internos ou fornecidos por terceiros.

A alocação de recursos para inovação estratégica é tratada por meio da orientação para decisões do órgão de governança sobre o uso de recursos entre projetos de inovação de curto, médio e longo prazos.

Este documento também fornece orientações que podem ser aplicadas no processo de *due diligence* (auditoria prévia) relacionado a aquisições de negócios. Este documento pode fornecer orientação sobre a aplicação dos princípios documentados na ABNT NBR ISO/IEC 38500 para classificar os investimentos habilitados para TI, incluindo a avaliação do valor e dos riscos dos elementos de TI no contexto de bancos de investimento ou realizados por empresas de investimento.

Este documento não prescreve ou determina práticas de gestão específicas necessárias para os investimentos habilitados para TI.

A ISO/IEC TS 38501 contém orientações sobre a estrutura de implementação para a governança eficaz de TI de forma geral. As estruturas da ISO/IEC TS 38501 podem ajudar a identificar fatores internos e externos relacionados à governança de TI, definir resultados benéficos e identificar evidências de sucesso. O ISO/IEC TR 38502 fornece orientações sobre a integração entre os órgãos de governança e a gestão da organização, de forma geral.

Este documento foi redigido de acordo com os princípios do ISO/IEC TR 38504:2016.

2 Referência normativa

O documento a seguir é citados no texto de tal forma que seu conteúdo, total ou parcial, constitui requisitos para este Documento. Para referências datadas, aplicam-se somente as edições citadas. Para referências não datadas, aplicam-se as edições mais recentes do referido documento (incluindo emendas).

ISO/IEC 38500:2015, *Information technology – Governance of IT for the organization*

3 Termos e definições

Para os efeitos deste documento, aplicam-se os seguintes termos e definições.

A ISO e a IEC mantêm as bases de dados terminológicos para uso na normalização nos seguintes endereços:

- ISO *Online browsing platform*: disponível em <https://www.iso.org/obp>
- IEC *Electropedia*: disponível em <https://www.electropedia.org/>

3.1

benefício

criação de vantagem, valor ou outro efeito positivo

[FONTE: ABNT NBR ISO 21505:2018, 3.4]

3.2

estrutura de governança

estratégias, políticas, estruturas de tomada de decisão e responsabilizações por meio das quais os arranjos de governança da organização operam

[FONTE: ISO/IEC TR 38502: 2017, 3.1]

3.3

investimentos habilitados por TI

investimentos que dependem do uso da tecnologia da informação para a obtenção de resultados de negócios

3.4

valor

ganho financeiro ou não financeiro quantificável

[FONTE: ISO 37500:2014, 3.25]

4 Boa governança de investimentos habilitados por TI

4.1 Benefícios da boa governança dos investimentos habilitados por TI

Quando os resultados dos investimentos em tecnologia são estabelecidos como ativos, e não apenas custos, eles se tornam um impulsionador estratégico de crescimento e de sustentabilidade para as organizações em um ambiente cada vez mais competitivo.

A boa governança dos investimentos habilitados por TI ajuda a organização a assegurar que esses investimentos contribuam positivamente para o desempenho e a conformidade da organização por meio de:

- priorização de investimentos que se alinhem com a estratégia e os objetivos de negócios da organização e tenham o potencial de retornar o maior valor para a organização;
- otimização do valor dos investimentos;
- fornecimento de um mecanismo para a mitigação adequada dos riscos dos investimentos;

- equilíbrio dos investimentos entre resultados de curto e longo prazos para assegurar a sustentabilidade contínua dos negócios;
- garantia da conformidade com as obrigações (regulatórias, legislativas, de direito comum e contratuais).

A governança inadequada desses investimentos pode expor a organização à perda de confiança de clientes e consumidores na marca, à inovação malsucedida ou atrasada, e a penalidades por não conformidade com obrigações legais e regulatórias.

4.2 Foco no valor

Convém que o valor para a organização de todo e qualquer investimento seja o primeiro e principal foco ao avaliar e priorizar investimentos.

O valor dos investimentos habilitados por TI não é obtido apenas pela implementação de TI. A obtenção de valor requer mudanças de negócios planejadas complementares, incluindo, mas não se limitando a, propósito, valores organizacionais, cultura, estrutura organizacional, processos de negócios, papéis e responsabilidades, habilidades pessoais e sistemas de recompensa. Para uma implementação bem-sucedida do investimento habilitado por TI, são necessários recursos de negócios significativos, e convém que o impacto nos negócios sempre seja considerado em primeiro lugar. As interdependências entre a estratégia de negócios e a tecnologia subjacente são inseparáveis. A realização de tais mudanças pode ser difícil de sustentar ao longo do tempo, e convém que o órgão de governança continue monitorando a capacidade da organização de manter o compromisso necessário com as mudanças nos negócios ao longo do tempo.

O valor pode estar relacionado ao aumento da participação de mercado, novas oportunidades desenvolvidas, aumento da satisfação do cliente ou melhor acesso ao cliente. Além disso, a redução direta de custos na terceirização de processos e a conformidade com regras e regulamentos também podem agregar valor à organização. Além disso, o valor pode ser devido a objetivos sociais ou ambientais. No entanto, convém que o valor esperado seja claramente definido e mensurável por um mecanismo aceito para assegurar a realização desse valor.

O valor da mudança de negócios pode ser possibilitado diretamente pela adoção de ativos e recursos de TI inovadores em novos serviços ou produtos de negócios. No entanto, convém que o valor indireto dos investimentos em ativos de TI subjacentes e de suporte, por exemplo, componentes de infraestrutura ou recursos de segurança, seja cuidadosamente avaliado, e convém que a manutenção contínua seja adequadamente priorizada dentro do portfólio de investimentos.

Ao considerar uma aquisição de negócios, a avaliação de valor pode ser obtida, garantindo que um processo estruturado de *due diligence* inclua a avaliação dos princípios e práticas de governança de TI executados, ativos de TI e recursos de TI.

Convém que a previsão de valor dos investimentos habilitados por TI, como em todos os investimentos, também seja avaliada em relação ao desvio de tempo e recursos de outras atividades de negócios. Convém que a priorização baseada em risco seja feita entre os produtos/serviços atuais e o desenvolvimento futuro de produtos/serviços.

Orientações específicas relacionadas ao foco no valor são feitas nas Seções 5 e 6.

4.3 Responsabilização do órgão de governança

O órgão de governança é, em última instância, responsável pelo sucesso de todos os investimentos realizados pela organização. Essa responsabilização decorre da função de governança geral da organização e, conseqüentemente, da governança da TI dentro da organização.

Convém que o órgão de governança exiba os mesmos comportamentos com todos os investimentos, independentemente de TI habilitada ou não.

Convém que o órgão de governança assuma e mantenha a responsabilização pela mudança nos negócios, assuma uma liderança visível e ativa, e defenda os investimentos, em vez de delegar toda a responsabilidade, como resultado, criando um ambiente para uma inovação estratégica bem-sucedida. Com visibilidade clara dos resultados, a criação de valor e a mitigação de riscos aumentarão a probabilidade de investimentos bem-sucedidos.

Convém que o órgão de governança estabeleça, promova e apoie um ambiente para permitir o sucesso dos investimentos da organização e forneça a liderança para apoiar as pessoas envolvidas.

Um ambiente sem surpresas para o órgão de governança e uma resposta de apoio às mensagens sobre possíveis problemas se baseia na confiança e transparência bidirecionais, e garante o alinhamento dos objetivos.

A responsabilização pelo uso eficaz, eficiente e aceitável da TI, e o sucesso dos investimentos da organização em TI permanecem com o órgão de governança e não é possível que sejam delegados. Manter um nível de engajamento da estrutura de governança aumenta significativamente o foco organizacional em resultados bem-sucedidos e na realização de valor de todos os investimentos.

O órgão de governança pode delegar a autoridade de tomada de decisão e responsabilizar a direção por aspectos dos investimentos, garantindo que a direção tenha a competência necessária para satisfazer tais responsabilidades associadas à delegação e que o próprio órgão de governança mantenha a visibilidade adequada das principais decisões. Convém que o órgão de governança comunique claramente a responsabilização da direção pelos resultados.

Convém que o órgão de governança mantenha a visibilidade dos investimentos que envolvam:

- um foco na inovação estratégica, com potencial para fornecer vantagem competitiva contínua de longo prazo;
- investimentos avaliados como de alto risco para a sustentabilidade da existência da organização;
- investimentos avaliados para exigir um compromisso de magnitude financeira significativa;
- altos níveis de integração com outros investimentos e/ou atividades empresariais.

5 Modelo de boa governança de investimentos habilitados por TI

5.1 Modelo de boa governança aplicado à governança de investimentos habilitados por TI

A ABNT NBR ISO/IEC 38500 introduz um modelo para a governança de TI que estabelece um ciclo de Avaliar – Direcionar - Monitorar. Este modelo “ADM” descreve as três principais tarefas de governança de TI e foi aplicado à governança de investimentos habilitados por TI nas seções a seguir.

A Figura 1 mostra o modelo aplicável a investimentos habilitados por TI. Esta Figura é baseada no modelo da ISO/IEC 38500:2015, Figura 1.

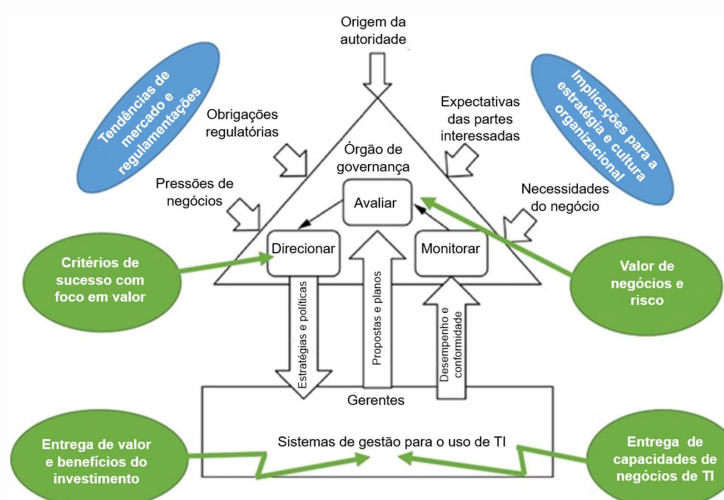


Figura 1 – Modelo de governança de TI

5.1.1 Avaliar

Ao aplicar o modelo da ABNT NBR ISO/IEC 38500, convém que as principais perguntas feitas pelo órgão de governança, ao avaliar os investimentos habilitados por TI, incluam o seguinte:

- Até que ponto o valor está sendo criado ou corroído pelos investimentos ao longo de todo o ciclo de vida da decisão de investimento?
- De que forma o portfólio de investimentos atende ao plano estratégico de negócios, ao desenvolvimento de recursos existentes e novos (negócios e TI) e é o momento certo para o negócio?
- A alocação de recursos entre investimentos de curto e longo prazos é adequada para garantir capacidades de negócios relevantes?
- Quais medidas estão sendo tomadas para aprimorar e proteger a reputação e a marca do negócio? A confiabilidade da organização está sendo considerada?
- Como os requisitos de segurança, privacidade, governança de dados legais, sociais e de negócios estão sendo aplicados?
- O perfil de risco do portfólio geral de investimentos habilitados por TI é suficientemente sustentável para os negócios e corresponde ao apetite de risco da organização?
- O equilíbrio entre crescimento, inovação e redução de custos é consistente com os objetivos estratégicos da organização para eficácia e eficiência de TI?
- De que forma as tecnologias emergentes estão sendo utilizadas para otimizar o crescimento futuro da organização?
- O nível geral de mudança de negócios é adequado para a capacidade da organização, clientes e partes interessadas externas?
- Quais são as barreiras organizacionais em que a assistência do órgão de governança é necessária para garantir um ambiente de sucesso?

- A abordagem proposta para entregar o investimento é apropriada e consistente com a direção estratégica futura em desenvolvimento *versus* aquisição, interno *versus* terceirização, serviço *versus* produto?

5.1.2 Direcionar

Convém que o órgão de governança direcione o estabelecimento de uma estrutura para controle e visibilidade dos investimentos que seja apropriada ao tamanho, número e tipo que estão sendo realizados. A estrutura de governança e o sistema de gestão podem:

- direcionar que o foco de todos os investimentos é criar e sustentar valor comercial de curto e longo prazos, em que o valor é uma função do alinhamento estratégico, benefícios, custos e riscos ao longo de todo o ciclo de vida de um investimento;
- direcionar que os investimentos incluam todas as mudanças de negócios necessárias para que o valor esperado seja realizado;
- direcionar que os investimentos devam ter um proprietário/patrocinador responsabilizado e que métricas pertinentes e mecanismos de *feedback* estejam em vigor para assegurar e garantir que o valor seja entregue;
- direcionar que os planos estratégicos de negócios incluam critérios de sucesso identificados para impulsionar os investimentos;
- direcionar políticas, processos, responsabilidades e responsabilizações claramente definidos para transparência na autoridade delegada de tomada de decisão;
- direcionar a velocidade, a pontualidade e a alocação de recursos necessários em relação ao investimento em inovação ou à aplicação de tecnologias atuais e futuras;
- direcionar a aplicação de *due diligence* apropriada para todos os tipos de investimentos;
- Direcionar a organização ao nível de capacidade, competência e maturidade esperado para lidar com os riscos e a complexidade exigidos, bem como para alcançar o valor e os benefícios desejados. estabelecer um ambiente organizacional e uma cultura que considere como o uso de TI impacta as pessoas e que seja direcionado para otimizar o valor do negócio;
- requerer uma avaliação de gestão de risco independente e responsabilizada, com separação de tarefas, utilizando recursos de negócios e de TI apropriados.

5.1.3 Monitorar

Convém que o órgão de governança monitore o desempenho e a conformidade dos investimentos para assegurar que eles estejam impulsionando os comportamentos e a entrega de valor mais eficazes e eficientes.

As principais considerações da tarefa de monitoramento para o órgão de governança podem incluir o seguinte:

- assegurar que os investimentos continuem alinhados com a estratégia e continuem a criar e sustentar valor para a organização;
- Monitorar continuamente para que exista um ambiente de confiança e transparência, destacando indicadores precoces de barreiras e soluções que demandem ação do órgão de governança.

- assegurar que um nível de tecnologia na organização esteja alinhado com as proposições estratégicas e com o apetite de risco do órgão de governança;
- desafiar as interdependências entre os investimentos que podem resultar na não entrega de valor ao negócio;
- monitorar se a organização tem a capacidade (ou habilidade) e a cultura para sustentar o nível necessário de mudança organizacional;
- monitorar o envolvimento das partes interessadas durante todo o investimento, incluindo se os proprietários de portfólio designados e outras partes interessadas estão fornecendo a responsabilização adequada em seus papéis e suporte organizacional;
- determinar se as condições e a estratégia de negócios mudaram durante o investimento, com as premissas originais ainda válidas e o valor ainda equilibrando o risco;
- monitorar tecnologias emergentes no mercado para potenciais perspectivas de investimento;
- assegurar que a continuidade dos negócios seja mantida;
- monitorar o uso eficaz, eficiente e aceitável de ativos e recursos de TI em relação a uma referência no mercado para subinvestimento prolongado.

6 Princípios para governança de investimentos habilitados por TI

6.1 Geral

A ABNT NBR ISO/IEC 38500 fornece seis princípios para a boa governança de TI. As subseções a seguir fornecem orientações sobre como esses princípios podem ser aplicados à governança de investimentos habilitados por TI.

As práticas descritas não são exaustivas, mas fornecem um ponto de partida para a orientação sugerida ao órgão de governança.

É responsabilidade de cada organização identificar individualmente as ações específicas necessárias para aplicar os princípios, levando em consideração a natureza e a estrutura da organização, bem como a natureza e o tipo de investimento habilitado por TI.

As implicações da aplicação dos princípios para o órgão de governança são pertinentes para os investimentos com os quais ele decidiu manter o envolvimento. Quando o órgão de governança delegar autoridade de tomada de decisão e responsabilizar a direção, essas implicações podem ser mais pertinentes para a direção da organização. No entanto, conforme descrito na Seção 4, o órgão de governança mantém a responsabilização geral pelo uso eficaz, eficiente e aceitável da TI e pelo sucesso dos investimentos da organização.

6.2 Princípio 1 – Responsabilidade

6.2.1 Aplicação do princípio

Indivíduos e grupos dentro da organização entendem e aceitam suas responsabilidades com relação aos investimentos habilitados por TI e têm autoridade e recursos adequados para entregar os resultados de negócios.

Mais importante ainda, a presença de um proprietário/patrocinador do investimento é um pré-requisito para iniciar qualquer carteira de investimentos. O papel do órgão de governança como patrocinador geral é crucial para o sucesso dos investimentos.

6.2.2 Implicações para o órgão de governança

As implicações da aplicação do princípio da responsabilidade são que convém que o órgão de governança:

- avalie as políticas e decisões que deseja manter (ou analisar criticamente) em seu nível como parte de suas responsabilidades gerais;
- avalie se os papéis e responsabilidades apropriados são identificados e atribuídos com relação ao ciclo de vida dos investimentos;
- avalie as competências daqueles que têm a responsabilidade de tomar decisões sobre investimentos;
- direcione o desenvolvimento e a implementação de uma estratégia clara de engajamento que aborde os papéis das áreas de negócios nos investimentos;
- monitore a eficácia dos arranjos de alocação de responsabilidade pela entrega de resultados de negócios a partir do uso da tecnologia.

6.2.3 Resultados desejados

Os resultados desejados da aplicação do princípio da responsabilidade podem incluir:

- os investimentos sejam bem-sucedidos na entrega de valor, conforme definido pelo órgão de governança, levando a uma maior disposição de investir adequadamente para alcançar resultados de negócios;
- tomada de decisão rápida em todos os níveis da organização;
- engajamento organizacional apropriado e uso das habilidades e capacidades necessárias nos processos de tomada de decisão para investimentos habilitados por TI.

6.2.4 Comportamentos de governança

Os comportamentos desejados da aplicação do princípio da responsabilidade são os seguintes:

- **Liderança:** A liderança do órgão de governança é clara e visível em toda a organização.
- **Tomada de decisão eficaz:** As delegações, responsabilidades e responsabilizações relacionadas aos investimentos são claramente definidas, compreendidas e aceitas por aqueles que recebem responsabilidades.
- **Patrocínio ativo:** Há um patrocínio ativo atribuído para apoiar que o alinhamento das perspectivas de negócios e TI seja incluído nos investimentos e que a conformidade com as obrigações regulatórias, legislativas e contratuais seja considerada.
- **Cultura de medição para melhoria:** A medição do sucesso do investimento habilitado por TI está incorporada na organização, levando a uma maior confiança e crença na realização do valor do investimento.

6.3 Princípio 2 – Estratégia

6.3.1 Aplicação do princípio

Convém que a estratégia defina a direção dos investimentos habilitados por TI, o que ser alcançado e como convém que a estratégia de TI seja alinhada à estratégia de negócios da organização, levando em consideração a criação ou erosão de valor e os riscos e restrições envolvidos com eles.

Convém que a estratégia de negócios da organização seja fonte de todos os investimentos de qualquer organização, independentemente do tipo, estrutura ou tamanho.

Convém que as estratégias de investimento assegurem que os ativos e capacidades de TI atuais e futuros, e os planos para o uso da TI, atendam às necessidades atuais e contínuas da estratégia de negócios da organização.

6.3.2 Implicações para o órgão de governança

As implicações da aplicação do princípio da estratégia são que convém que o órgão de governança:

- avalie se os investimentos estão alinhados com a estratégia geral de negócios e se fornecem o valor e o retorno do investimento requerido para a organização;
- avalie e formule uma posição sobre inovação a partir do investimento e uso comercial de TI;
- avalie regularmente as oportunidades de investimento em TI para melhorar os imperativos organizacionais, como os arranjos da cadeia de valor, a fim de manter a vantagem competitiva da organização;
- avalie se são tomadas decisões eficazes e oportunas sobre investimentos em apoio às metas de mudança de negócios;
- avalie o momento do investimento crítico para o sucesso, incluindo a estratégia correta com relação aos investimentos simultâneos e a provisão realista para um programa de investimento;
- direcione a preparação e implementação de estratégias e políticas, demonstrando uma compreensão do apetite global ao risco da organização, nível de apoio a usos inovadores de TI que permitam que a organização responda a novas oportunidades e um futuro focado na digitalização;
- direcione o compromisso e lidere a estratégia e seus direcionadores para sustentar a estratégia de negócios com a tecnologia para garantir o sucesso contínuo da organização;
- direcione que a estratégia de investimento em TI seja amplamente comunicada para fornecer a base para a coordenação de várias iniciativas em toda a organização;
- direcione a estratégia para aquisições de negócios e modelos de *sourcing* em relação ao impacto nas decisões de investimento;
- monitore o desempenho geral da estratégia de investimento em TI da organização em apoio à estratégia da organização.

6.3.3 Resultados desejados

Os resultados desejados da aplicação do princípio da estratégia podem incluir:

- todos os investimentos estão alinhados à entrega de valor ao negócio, independentemente do tipo, estrutura ou porte da organização ou de quem os implementa;
- as estratégias, arquiteturas e políticas de TI apoiam os requisitos contínuos das empresas para fornecer ativos e recursos de TI novos e alterados;
- existe uma abordagem sistemática para incentivar a inovação no uso de TI;
- um cenário de TI sustentável que apoie a estratégia de negócios das organizações e o crescimento contínuo das receitas;
- uma cultura de compreensão da relação entre as oportunidades digitais e a estratégia de negócios.

6.3.4 Comportamentos de governança

Os comportamentos desejados da aplicação do princípio da estratégia são os seguintes:

- **Reconhecimento da importância estratégica do investimento em TI:** O órgão de governança demonstra interesse e engajamento na estratégia de TI para investimentos da mesma maneira que a estratégia de negócios.
- **Uso eficaz, eficiente e aceitável da TI:** Convém que a estratégia de investimento assegure uma utilização eficaz, eficiente e aceitável das tecnologias da informação.
- **Requisito de valor demonstrável de investimentos em TI:** A estratégia de investimentos apoia a obtenção do valor comercial e dos benefícios desejados pela organização.
- **Estratégia de inovação:** As estratégias e políticas de inovação fornecem uma orientação clara para a execução de investimentos que apoiem a adoção das tecnologias disponíveis atuais e futuras.

6.4 Princípio 3 – Aquisição

6.4.1 Aplicação do princípio

As aquisições de TI são feitas por razões válidas em apoio à estratégia de investimento planejada e no valor previsto a ser alcançado, com base em análises apropriadas, contínuas e apoiadas por um processo de tomada de decisão claro e transparente. Existe um equilíbrio adequado entre benefícios, oportunidades, custos e riscos, tanto a curto quanto a longo prazo.

Convém que o órgão de governança assegure que os recursos apropriados estejam disponíveis antes, durante e depois de qualquer investimento habilitado por TI e que sejam feitos de acordo com um processo de tomada de decisão claro e transparente.

6.4.2 Implicações para o órgão de governança

As implicações da aplicação do princípio da aquisição são que convém que o órgão de governança:

- avalie se os recursos estratégicos necessários e apropriados, fontes e capacidades legais estão disponíveis para a conclusão bem-sucedida dos investimentos em tempo hábil;

- direcione a adoção de metodologia estruturada de *due diligence* e a estrutura para equilibrar riscos e custo-benefício dos investimentos propostos;
- direcione que os arranjos de fornecimento (incluindo arranjos de fornecimento internos e externos) apoiem a mudança de negócios desejada da organização;
- direcione que, ao fazer qualquer aquisição de TI, tanto a organização quanto os fornecedores desenvolvam um entendimento compartilhado da intenção da organização em termos de resultados desejados;
- monitore toda a cadeia de suprimentos fornecida pelas aquisições de TI, para assegurar que elas forneçam os recursos de negócios, ativos de TI e recursos de TI necessários.

6.4.3 Resultados desejados

Os resultados desejados da aplicação do princípio da aquisição podem incluir:

- melhor integração das perspectivas de negócios e TI antes, durante e depois dos investimentos, incluindo decisões de aquisições habilitadas por TI;
- governança de TI, ativos de TI e recursos de TI incluídos em relatórios de *due diligence* para avaliar o investimento habilitado por TI em relação ao risco de negócios e valor agregado.

6.4.4 Comportamentos de governança

Os comportamentos desejados da aplicação do princípio de aquisição são:

- **Aquisições de TI tratadas como investimentos de negócios:** Leva em conta os recursos e o uso contemporâneo da TI e garante que os planos estratégicos de negócios conduzam a agenda de aquisições de TI da organização.
- **TI considerada um ativo de valor:** A tecnologia, digital ou tradicional, é estabelecida como um ativo de valor para a organização, em vez de um elemento de custo, e se torna um ativo de crescimento e divisor de águas para a organização.
- **A metodologia de *due diligence* de investimento habilitada por TI é estabelecida:** A metodologia para aquisições de TI inclui supervisão de risco apropriada e aprovações antes, durante e depois da tomada de decisão de investimento em TI.

6.5 Princípio 4 – Desempenho

6.5.1 Aplicação do princípio

Os investimentos são adequados ao propósito de apoiar a organização, fornecer os serviços, níveis de serviço e qualidade de serviço necessários para atender aos requisitos de negócios atuais e futuros, criando valor para a organização e alavancando a vantagem competitiva no mercado.

6.5.2 Implicações para o órgão de governança

As implicações da aplicação do princípio do desempenho são que convém que o órgão de governança:

- avalie o valor criado para a organização pelos investimentos;
- avalie se os investimentos são adequados ao propósito de apoiar as necessidades atuais e futuras do negócio;

- avalie regularmente o desempenho da estrutura de governança da organização para investimentos;
- determine que as métricas de desempenho pertinentes sejam identificadas, documentadas e operacionais, recebendo atenção apropriada e medidas corretivas, se necessário;
- direcione os investimentos aceitáveis adequados ao propósito de apoiar a organização;
- monitore até que ponto os investimentos apoiam e criam valor e benefícios para a organização;
- monitore até que ponto os investimentos estão alinhados aos objetivos de mudança de negócios;
- monitore até que ponto as políticas relacionadas aos investimentos são seguidas adequadamente;
- monitore o valor e os benefícios relacionados aos investimentos em inovação.

6.5.3 Resultados desejados

Os resultados desejados da aplicação do princípio de desempenho podem incluir:

- menor risco e melhor transparência no valor de curto e longo prazos dos investimentos;
- todos os resultados exigidos atendidos, conforme definido pela estratégia da organização e proposta de investimento de maneira mensurável e identificável;
- mensuração do valor e dos benefícios em relação ao plano;
- desempenho nos requisitos de conformidade com os investimentos são rastreados e relatados.

6.5.4 Comportamentos de governança

Os comportamentos desejados da aplicação do princípio de desempenho são os seguintes:

- **Transparência na avaliação de desempenho:** Os meios de garantir a transparência na avaliação do desempenho dos resultados comerciais alcançados dos investimentos são assegurados, acompanhados e ajustados conforme necessário e os mecanismos necessários para monitorar o desempenho são claros e visíveis.
- **Reconhecimento de riscos e mitigação adequada:** Os possíveis riscos relacionados aos investimentos são identificados, tratados e monitorados de acordo com a gestão de riscos adequada implementada.
- **Realização de valor:** Monitorar e controlar o valor e os benefícios para a organização relacionados aos investimentos.
- **Suporte contínuo para investimentos habilitados por TI, dependendo do desempenho:** A boa governança do investimento habilitado por TI leva diretamente à seleção, à implementação e ao uso mais eficazes e eficientes da tecnologia, alcançando os resultados de negócios desejados.

6.6 Princípio 5 – Conformidade

6.6.1 Aplicação do princípio

Os investimentos cumprem todas as legislações e regulamentos obrigatórios e outros requisitos internos ou externos. As políticas e práticas para garantir a conformidade antes, durante e após a execução dos investimentos são claramente definidas, implementadas e aplicadas.

6.6.2 Implicações para o órgão de governança

As implicações da aplicação do princípio da conformidade são que convém que o órgão de governança:

- avalie riscos relacionados ao cumprimento de obrigações (regulatórias, legislativas e contratuais) relativas a investimentos;
- avalie regularmente a conformidade interna da organização com sua estrutura de governança para investimentos;
- direcione que as políticas relacionadas a investimentos sejam estabelecidas e aplicadas para permitir que a organização cumpra suas obrigações externas e internas;
- monitore as atividades de investimentos regularmente para assegurar que as obrigações de conformidade relacionadas (regulatórias, legislativas e contratuais), incluindo privacidade, proteção de dados, propriedade intelectual, saúde e segurança, financeiras e outras obrigações internas, sejam cumpridas.

6.6.3 Resultados desejados

Os resultados desejados da aplicação do princípio de conformidade podem incluir:

- os investimentos melhoram a capacidade das organizações de se adequarem aos requisitos regulamentares, legislativos e contratuais, garantindo a licença da organização para operar;
- os investimentos apoiam o cumprimento da obrigação das organizações de relatar a conformidade de forma eficiente;
- os investimentos são realizados de forma que as partes interessadas externas e internas confiem na posição ética das organizações em relação à conformidade com as obrigações regulatórias, legislativas e contratuais, bem como com os resultados comerciais do investimento;
- os avanços tecnológicos são adotados com sucesso pelos clientes e pela organização sem quaisquer impactos adversos nas obrigações regulatórias, legislativas e contratuais.

6.6.4 Comportamentos de governança

Os comportamentos desejados da aplicação do princípio de conformidade são os seguintes:

- **Exigir conformidade regulatória dentro do apetite de risco organizacional:** O investimento habilitado por TI identifica obrigações legislativas, regulatórias e contratuais, o risco associado e a mitigação, e aplica meios para atendê-las.
- **Reconhecer as implicações na metodologia de *due diligence* de investimento habilitada por TI:** A conformidade com os requisitos regulatórios, legislativos e contratuais realizados por potenciais oportunidades de aquisição é avaliada como parte do processo de *due diligence*.

6.7 Princípio 6 – Comportamento humano

6.7.1 Aplicação do princípio

As políticas, práticas e decisões relacionadas com os investimentos demonstram respeito pelo comportamento humano, incluindo as necessidades e preocupações atuais e em evolução de todas as «pessoas no processo».

Convém que seja estabelecida uma cultura organizacional que incentive todas as partes a se alinharem aos objetivos gerais e a trabalharem para os resultados de negócios desejados. Por meio da liderança do órgão de governança, uma cultura da organização é incorporada em todos os níveis, permitindo inovação digital, conquistas, colaboração, confiança e transparência nos padrões éticos.

Mais importante ainda, o desenvolvimento de competências de TI relativas às responsabilidades organizacionais e uma compreensão do comportamento humano são necessários para permitir uma integração mais próxima da estratégia de negócios e da implementação da tecnologia.

6.7.2 Implicações para o órgão de governança

As implicações da aplicação do princípio do comportamento humano são que convém que o órgão de governança:

- avalie meios de liderança para implementar uma cultura apropriada de comportamento humano e inovação que apoie um nível apropriado de digitalização para a organização;
- determine que o comportamento humano antes, durante e após a implementação seja levado em consideração e que seja consistente, ético e siga diretrizes pertinentes para o comportamento profissional e o desenvolvimento de competências;
- direcione que riscos, oportunidades, problemas e preocupações relacionados a investimentos possam ser identificados e relatados por qualquer pessoa a qualquer momento;
- direcione que os conflitos de interesses sejam identificados e mitigados em relação às aquisições de TI;
- monitore se as políticas, práticas e decisões relacionadas a investimentos demonstram respeito pelo comportamento humano;
- monitore o uso aceitável de tecnologias como IA.

6.7.3 Resultados desejados

Os resultados desejados da aplicação do princípio do comportamento humano podem incluir:

- a cultura é focada nas partes interessadas externas e internas e integra as perspectivas de negócios e tecnologia, levando em consideração o comportamento humano na tomada de decisões de investimento;
- a cultura de inovação é compreendida, aceita e adotada em toda a organização;
- funcionários em todos os níveis da organização executam oportunidades para aumentar seu nível de competências pertinentes de TI;
- a organização adota rapidamente novas competências de TI, tem maior probabilidade de ser pioneira no uso da tecnologia digital e abraça com sucesso oportunidades de negócios inovadoras;
- os investimentos resultarão na implementação e uso sustentável de tecnologias em evolução, consistentes com o comportamento humano identificado.

6.7.4 Comportamentos de governança

Os comportamentos desejados da aplicação do princípio do comportamento humano são os seguintes:

- **Adoção da cultura da organização de aprendizagem para apoiar os investimentos em TI:** Convém que as políticas e procedimentos de competências de TI estejam presentes para apoiar a identificação de competências de TI relevantes a serem alcançadas, bem como um orçamento e uma estrutura de aprovação que garanta uma execução eficiente e eficaz das oportunidades.
- **Alinhamento e foco:** Todos os recursos estão focados na execução em direção aos resultados desejados de mudança de negócios, desde o órgão de governança até as pessoas que entregam os investimentos.
- **Cultura de inovação:** Convém que uma cultura de adoção inovadora de tecnologias em evolução seja alavancada e apoiada pelo órgão de governança.
- **Reconhecimento da gestão de riscos:** Políticas e procedimentos são publicados e implementados para assegurar que riscos, oportunidades, questões e preocupações relacionados a conflitos de interesses e comportamentos humanos éticos em relação a investimentos sejam identificados e relatados por qualquer pessoa, a qualquer momento, e encaminhados aos tomadores de decisão relevantes para avaliação e mitigação.

Bibliografia

- [1] ISO/IEC TS 38501:2015, *Information technology – Governance of IT – Implementation guide*
- [2] ISO/IEC TR 38502:2017, *Information technology – Governance of IT – Framework and model*
- [3] ISO/IEC TR 38504:2016, *Governance of information technology – Guidance for principles-based standards in the governance of information technology*

